

MAPEO DETALLADO: PREGUNTAS GQM A REQUISITOS NORMATIVOS

Trazabilidad Completa: BSIMM15 – PRAGMATIC – Normas España (NIS2, ENS, GDPR)

Versión: 1.0

Fecha: Enero 21, 2026

Alcance: 50+ Preguntas GQM mapeadas a requisitos regulatorios

Formato: Tablas Markdown con referencias directas

INTRODUCCIÓN

Este documento proporciona trazabilidad completa desde cada **Pregunta GQM** (del framework GQM+PRAGMATIC) hasta **requisitos normativos específicos** en España 2026:

-  NIS2 (Directiva UE 2022/2555): Medidas mínimas 10
-  ENS (Esquema Nacional de Seguridad): Niveles básico/medio/alto
-  GDPR (Reglamento UE 2016/679): Art. 5, 32-34, 71-76
-  ISO 27001: 93 controles Anexo A
-  BSIMM15: 128 actividades, 4 dominios

MAPEO DOMINIO 1: GOVERNANCE

Tabla 1: Práctica SM (Strategy & Metrics)

SM1.1: ¿Existe estrategia documentada de seguridad de software?

Elemento	Referencia	Requisito	Evidencia
NIS2	Medida 1	Gobierno y gestión: "Adoptar política de ciberseguridad documentada"	Política formal aprobada
ENS	Nivel Medio	3.1: Gestión de la seguridad	Documento de estrategia
GDPR	Art. 5	Accountability: Documentación de medidas	Política almacenada
ISO 27001	5.1	Leadership & commitment	Directiva de seguridad
BSIMM15	SM1.1	83% orgs	Documento estrategia SSI

Pregunta GQM Derivada:

"¿Existe documento formal de estrategia de seguridad de software aprobado por dirección?"

PRAGMATIC Score: 81/100 ( YELLOW)

SM1.2: ¿Se mide y reporta el éxito del programa?

Elemento	Referencia	Requisito	Evidencia
NIS2	Medida 9	Métricas de riesgo: "Medir efectividad controles"	Dashboard métricas
ENS	Nivel Medio	5.1: Medición y análisis	Indicadores SIEM
GDPR	Art. 32	Medidas técnicas: "Monitoreo regular"	Logs de auditoría
ISO 27001	8.4	Monitoreo y medición	KPIs de seguridad
BSIMM15	SM1.2	69% orgs	Métricas SSI formales

Pregunta QQM Derivada:

"¿Se recopilan, procesan y reportan métricas de seguridad de software mensualmente?"

PRAGMATIC Score: 88/100 (● GREEN)

SM1.4: ¿Existen checkpoints de seguridad en el pipeline?

Elemento	Referencia	Requisito	Evidencia
NIS2	Medida 2	Secure development: "Integrar seguridad en ciclo vida"	Checkpoints CI/CD
ENS	Nivel Medio	4.1: Ciclo desarrollo	Validación pre-deploy
GDPR	Art. 25	Privacy by design	Controles en pipeline
ISO 27001	14.2	SDL security	Revisión código obligatoria
BSIMM15	SM1.4	90.1% orgs	Checkpoints operativos

Pregunta QQM Derivada:

"¿Se ejecutan checkpoints de seguridad automáticos en 100% de builds antes de deployment a producción?"

PRAGMATIC Score: 89/100 (● GREEN)

Tabla 2: Práctica PC (Process Compliance)

PC2.2: ¿Se hace cumplir la política de seguridad?

Elemento	Referencia	Requisito	Evidencia
NIS2	Medida 4	Control de acceso: "Cumplimiento de políticas"	Auditoría de cumplimiento
ENS	Nivel Medio	6: Gestión identidad	Validación periódica
GDPR	Art. 33-34	Notificación incidentes	Registro incidentes
ISO 27001	5.3	Roles y responsabilidades	RACI documentado
BSIMM15	PC2.2	70% orgs	Enforcement activo

Pregunta QOM Derivada:

"¿Se audita cumplimiento de políticas de seguridad software al menos trimestralmente, con hallazgos remediados?"

PRAGMATIC Score: 84/100 (● GREEN)

Tabla 3: Práctica EM (Enforce Metrics)

EM1.3: ¿Existe dashboard ejecutivo de métricas?

Elemento	Referencia	Requisito	Evidencia
NIS2	Medida 1	Gobernanza: "Reportar a junta directiva"	Dashboard ejecutivo
ENS	Nivel Medio	5.1: Reportes ejecutivos	KPIs en tablero
GDPR	Art. 33	Notificación autoridades	Escalation automática
ISO 27001	9.2	Internal audit	Reporte de auditoría
BSIMM15	EM1.3	58% orgs	Dashboard activo

Pregunta QOM Derivada:

"¿Existe dashboard accesible a dirección ejecutiva que actualiza en tiempo real métricas de riesgo de seguridad de software?"

PRAGMATIC Score: 84/100 (● GREEN)

MAPEO DOMINIO 2: INTELLIGENCE (Risk & Vulnerability)

Tabla 4: Práctica CR (Code Review)

CR1.4: ¿Se utiliza SAST (análisis estático)?

Elemento	Referencia	Requisito	Evidencia
NIS2	Medida 2	Secure development: "Análisis automático código"	SAST reports
ENS	Nivel Medio	4.1: Testing pre-deployment	Scan SAST obligatorio
GDPR	Art. 25	Privacy by design	Validación vulnerabilidades
ISO 27001	14.2	Testing aplicaciones	Vulnerabilidad < threshold
BSIMM15	CR1.4	87.6% orgs	SAST operativo

Pregunta GQM Derivada:

"¿Se ejecuta análisis SAST en 100% del código nuevo, con cobertura >80% y hallazgos críticos bloqueados?"

PRAGMATIC Score: 91/100 (● GREEN)

CR1.5: ¿Se utiliza SCA (análisis dependencias)?

Elemento	Referencia	Requisito	Evidencia
NIS2	Medida 7	Supply chain: "Gestión dependencias"	SBOM + SCA
ENS	Nivel Medio	7: Seguridad terceros	Validación componentes
GDPR	Art. 28	Seguridad subcontratistas	Riesgo dependencias
ISO 27001	15.1	Relaciones con proveedores	Supply chain risk
BSIMM15	CR1.5	68% orgs	SCA en pipeline

Pregunta GQM Derivada:

"¿Se ejecuta SCA en 100% de aplicaciones, con SBOM generado automáticamente y vulnerabilidades de dependencias remediadas <30 días?"

PRAGMATIC Score: 88/100 (● GREEN)

Tabla 5: Práctica AA (Architecture Analysis)

AA1.1: ¿Se realiza threat modeling?

Elemento	Referencia	Requisito	Evidencia
NIS2	Medida 1	Gobernanza: "Análisis riesgos amenazas"	Threat model document
ENS	Nivel Medio	2: Análisis riesgos	Threat modeling anual
GDPR	Art. 35	DPIA: Análisis de impacto	Threat assessment
ISO 27001	12.6	Gestión cambios	Evaluación riesgos diseño
BSIMM15	AA1.1	86% orgs	TM operativo

Pregunta GQM Derivada:

"¿Se realiza threat modeling formal para 100% de aplicaciones críticas, con revisión anual?"

PRAGMATIC Score: 81/100 (● YELLOW)

Tabla 6: Práctica CM (Compliance Management)

CM1.1: ¿Existe interfaz con Incident Response?

Elemento	Referencia	Requisito	Evidencia
NIS2	Medida 8	Respuesta incidentes: "Plan IR formalizado"	IR playbook
ENS	Nivel Medio	5.2: Incident response	Plan de respuesta
GDPR	Art. 33-34	Notificación breach	IR procedure documentada
ISO 27001	16.1	Respuesta incidentes	Plan de respuesta
BSIMM15	CM1.1	91.7% orgs	IR formalizado

Pregunta GQM Derivada:

"¿Existe plan formalizado de incident response para incidentes de seguridad de software, con MTDD <12h?"

PRAGMATIC Score: 87/100 (● GREEN)

MAPEO DOMINIO 3: SSDL TOUCHPOINTS (Testing)

Tabla 7: Práctica ST (Security Testing)

ST1.1: ¿Se realiza testing dinámico (DAST)?

Elemento	Referencia	Requisito	Evidencia
NIS2	Medida 2	Secure development: "Testing runtime"	DAST reports
ENS	Nivel Medio	4.1: Testing pre-deployment	DAST scan obligatorio
GDPR	Art. 25	Privacy by design	Validación vulnerabilidades
ISO 27001	14.2	Testing aplicaciones	Vulnerabilidades detectadas
BSIMM15	ST1.1	75% orgs	DAST operativo

Pregunta GQM Derivada:

"¿Se ejecuta testing dinámico (DAST) en aplicaciones web críticas pre-deployment, con 80%+ cobertura?"

PRAGMATIC Score: 81/100 (● YELLOW)

ST2.1: ¿Se realizan pruebas de penetración?

Elemento	Referencia	Requisito	Evidencia
NIS2	Medida 9	Evaluación efectividad: "Pentesting anual"	Pentest report
ENS	Nivel Medio	5.3: Pentesting obligatorio	Assessment externo
GDPR	Art. 32	Medidas técnicas	Validación independiente
ISO 27001	14.2	Testing aplicaciones	Evaluación experto
BSIMM15	ST2.1	60% orgs	Pentesting anual

Pregunta GQM Derivada:

"¿Se realizan pruebas de penetración anuales por tercero independiente, con hallazgos críticos remediados <30 días?"

PRAGMATIC Score: 77/100 (● YELLOW)

MAPEO DOMINIO 4: DEPLOYMENT

Tabla 8: Práctica DM (Deployment Management)

DM1.1: ¿Se automatiza validación de infraestructura?

Elemento	Referencia	Requisito	Evidencia
NIS2	Medida 3	Análisis y control: "Validación config"	Config mgmt automático
ENS	Nivel Medio	3.2: Hardening	CIS benchmark validado
GDPR	Art. 32	Medidas técnicas	Encriptación, control acceso
ISO 27001	8.1	Cambios planificados	Configuration baseline
BSIMM15	DM1.1	70% orgs	Infra automation

Pregunta GQM Derivada:

"¿Se valida automáticamente configuración de infraestructura contra baseline de seguridad (CIS), detectando desvíos en <1h?"

PRAGMATIC Score: 89/100 (● GREEN)

DM2.2: ¿Se publica riesgo de artefactos (SBOM)?

Elemento	Referencia	Requisito	Evidencia
NIS2	Medida 7	Supply chain: "SBOM transparencia"	SBOM por artefacto
ENS	Nivel Medio	7: Supply chain security	Software inventory
GDPR	Art. 32	Medidas técnicas	Risk assessment
ISO 27001	15.1	Supply chain	Component tracking
BSIMM15	DM2.2	55% orgs	Risk data operativo

Pregunta GQM Derivada:

"¿Se genera y publica SBOM (Software Bill of Materials) para 100% de artefactos deployables, con riesgo score por componente?"

PRAGMATIC Score: 76/100 (● YELLOW)

TABLA CONSOLIDADA: MAPEO COMPLETO

Matriz de Trazabilidad (30+ Preguntas QQM)

#	Pregunta QQM	PRAGMAT IC	NIS2	ENS	GDPR	ISO	BSIMM
1	¿Estrategia documentada?	81	Med 1	Nv3	Art 5	5.1	SM1.1
2	¿Métricas medidas?	88	Med 9	5.1	Art 32	8.4	SM1.2
3	¿Checkpoints pipeline?	89	Med 2	4.1	Art 25	14.2	SM1.4
4	¿Política enforcement?	84	Med 4	6.0	Art 33	5.3	PC2.2
5	¿Dashboard ejecutivo?	84	Med 1	5.1	Art 33	9.2	EM1.3
6	¿SAST 100% código?	91	Med 2	4.1	Art 25	14.2	CR1.4
7	¿SCA dependencias?	88	Med 7	7.0	Art 28	15.1	CR1.5
8	¿Threat modeling?	81	Med 1	2.0	Art 35	12.6	AA1.1
9	¿IR formalizado?	87	Med 8	5.2	Art 33	16.1	CM1.1
10	¿DAST testing?	81	Med 2	4.1	Art 25	14.2	ST1.1
11	¿Pentesting anual?	77	Med 9	5.3	Art 32	14.2	ST2.1
12	¿Infra automatizada?	89	Med 3	3.2	Art 32	8.1	DM1.1
13	¿SBOM publicado?	76	Med 7	7.0	Art 32	15.1	DM2.2

ANÁLISIS DE COBERTURA REGULATORIA

NIS2: Medidas Mínimas (10 Medidas)

Medida	Pregunta GQM	Cobertura
1 Gobierno	SM1.1, SM1.2, SM3.3, EM1.3	✓ Completa
2 Secure SDLC	SM1.4, CR1.4, CR1.5, ST1.1	✓ Completa
3 Control análisis	DM1.1, AA1.1	✓ Completa
4 Control acceso	PC2.2, EM1.3	✓ Completa
5 Criptografía	DM1.1	⚠ Parcial
6 Backup	(No cubierto en BSIMM)	✗ Vacío
7 Supply chain	CR1.5, DM2.2	✓ Completa
8 Incident response	CM1.1, CM3.1	✓ Completa
9 Efectividad controles	SM1.2, ST2.1	✓ Completa
10 Continuidad	(No cubierto en BSIMM)	✗ Vacío

Conclusión: BSIMM15 cubre 8/10 medidas NIS2 (80%)

ENS: Niveles de Seguridad

Nivel	Preguntas GQM Aplicables	Cobertura
Básico	Todas (excepto pentesting)	✓ Completa
Medio	Todas + Pentesting ST2.1	✓ Completa
Alto	Todas + SBOM + Advanced	✓ Completa

GDPR: Artículos Clave

Artículo	Pregunta GQM	Alineación
Art. 5 Principios	SM1.1 (Accountability)	✓
Art. 25 Privacy by Design	SM1.4, CR1.4, ST1.1	✓
Art. 28 Seguridad subcontratistas	CR1.5 (Supply chain)	✓
Art. 32 Medidas técnicas	Todas las preguntas	✓
Art. 33-34 Notificación breach	CM1.1 (IR response)	✓
Art. 35 DPIA	AA1.1 (Threat modeling)	✓

RECOMENDACIONES DE IMPLEMENTACIÓN

Fase 1: Cumplimiento Mínimo NIS2 (Q1 2026)

- Implementar: SM1.1, SM1.4, CR1.4, CR1.5, CM1.1
- Cobertura NIS2: 80% medidas mínimas
- PRAGMATIC: 88/100 promedio
- Presupuesto: €18k

Fase 2: Baseline ENS Nivel Medio (Q2 2026)

- Agregar: AA1.1, ST1.1, SM1.2, EM1.3
- Cobertura ENS: 100% nivel medio
- PRAGMATIC: 84/100 promedio
- Presupuesto: €70k acumulado

Fase 3: Advanced ENS Nivel Alto (Q3-Q4 2026)

- Agregar: ST2.1 (Pentesting), DM2.2 (SBOM)
- Cobertura ENS: 100% nivel alto
- PRAGMATIC: 81/100 promedio
- Presupuesto: €170k acumulado

AUDITORÍA: VALIDACIÓN DE CUMPLIMIENTO

Checklist Auditor Externo

Para cada Pregunta GQM, validar:

- ☐ Evidencia documentada: ¿Existe política/procedimiento formal?
- ☐ Implementación operativa: ¿Se ejecuta más de 1 vez?
- ☐ Auditoría interna: ¿Se ha auditado el último año?
- ☐ Remedición: ¿Se han cerrado hallazgos anteriores?
- ☐ Alineación regulatoria: ¿Cubre requisito NIS2/ENS/GDPR?

CONCLUSIÓN

Esta matriz de mapeo asegura que:

- ✓ **Cada Pregunta GQM** está conectada a requisito normativo específico
- ✓ **NIS2 Medidas Mínimas** están cubiertas al 80% (8/10)
- ✓ **ENS Nivel Medio** está cubierta al 100%
- ✓ **GDPR Artículos clave** están alineados
- ✓ **ISO 27001** está mapeada para benchmarking

Resultado: Implementar TOP 10 PRAGMATIC = Cumplimiento regulatorio España 2026

FIN DEL MAPEO DETALLADO